Aula 3 - Certificados SSL e o Protocolo HTTPS, Métodos de autenticação

Prof. Henrique Batista da Silva

Na aula de hoje

- Certificados SSL e o Protocolo HTTPS, Métodos de autenticação.

Introdução

Integridade de mensagem

- Vimos até aqui que a criptografia pode ser usada para oferecer sigilo as duas entidades na comunicação.
- Agora veremos como prover integridade da mensagem

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Integridade de mensagem

- Exemplo:
  - Suponha que Bob receba uma mensagem (cifrada ou em texto aberto), acreditando que ela tenha sido enviada por Alice.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Integridade de mensagem

- Exemplo (cont..):
  - Para autenticar a mensagem, Bob precisa verificar:
    - A mensagem foi realmente enviada por Alice
    - A mensagem não foi alterada a caminho de Bob
  - O problema da integridade de mensagem é uma preocupação importante nos protocolos seguros.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Integridade de mensagem

- Permite a comunicação das partes para verificar que as mensagens recebidas são autênticas.
  - conteúdo da mensagem não foi alterado
  - origem da mensagem é quem/o que você pensa ser
  - mensagem não foi reproduzida
  - sequência de mensagens é mantida

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Integridade de mensagem

- Primeiro, vamos falar sobre resumos de mensagem

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Resumo de Mensagens

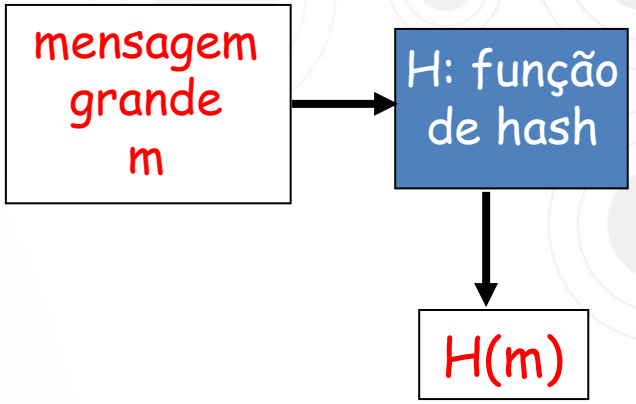
Resumo de Mensagens

- A função hash recebe uma entrada m e computa a cadeia de tamanho fixo H(m), conhecida como *hash*: "assinatura da mensagem".

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Resumo de Mensagens

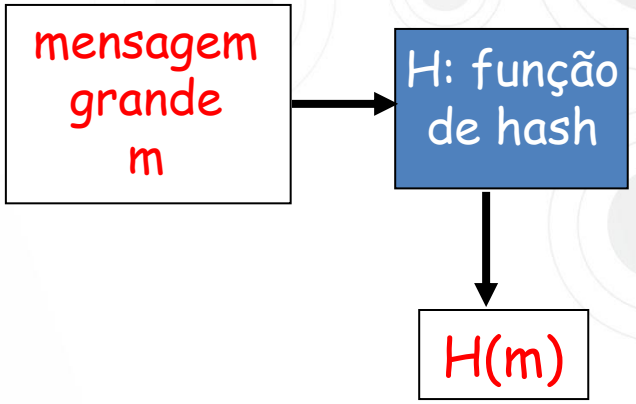
- Deve satisfazer o seguinte:
  - é impraticável encontrar duas mensagens diferentes x e y tal que H(x) = H(y)



Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Resumo de Mensagens

- Ou seja, um invasor não consegue substituir uma mensagem por outra (forjar uma mensagem).



Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Soma de verificação da Internet: resumo de mensagem fraco

- Dada a mensagem com dado valor de hash, é fácil achar outra mensagem com o mesmo valor de hash?

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Soma de verificação da Internet: resumo de mensagem fraco

- Exemplo: soma de verificação simplificada: soma porções de 4 bytes de cada vez:
  - Imagine que Bob deva a Alice 100,99 dólares e lhe envie um vale com a sentença 'IOU100.88BOB' (I Owe You – Eu lhe devo)

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Soma de verificação da Internet: resumo de mensagem fraco

mensagem	formato ASCII			
I O U 1	49	4F	55	31
0 0 . 9	30	30	2E	39
9 B O B	39	42	D2	42
	B2	C1	D2	AC

mensagem	formato ASCII			
I O U 9	49	4F	55	39
0 0 . 1	30	30	2E	31
9 B O B	39	42	D2	42
	B2	C1	D2	AC

mensagens diferentes
mas somas de verificação idênticas!

Soma de verificação

Viola o princípio citado anteriormente, pois oferecida duas mensagens diferentes, encontramos a mesma função hash. Precisamos de uma função hash muito mais poderosa que a soma de verificação.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Algoritmos de função de hash

- função de hash MD5 bastante usada
  - calcula resumo de mensagem de 128 bits
- SHA-1 também é usado.
  - padrão nos EUA
  - resumo de mensagem de 160 bit, mais seguro

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Message Authentication Code (MAC)

Message Authentication Code (MAC)

- Retornamos ao problema da integridade da mensagem
  1. Alice cria a mensagem m e calcula o hash H(m).
  2. Alice anexa H(m) à mensagem m, criando uma mensagem estendida (m, H(m)), e a envia para Bob.
  3. Bob recebe uma mensagem estendida (m, h) e calcula H(m). Se H(m) = h, Bob conclui que está tudo certo.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Message Authentication Code (MAC)

- Não daria certo, pois um invasor poderia se passar por Alice e criar uma mensagem m', calcular H(m') e enviar a bob. Na etapa 3 tudo se encaixaria.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Message Authentication Code (MAC)

- Para usar a integridade de mensagem, além de usar as funções hash, Alice e Bob precisam de um segredo compartilhado s (chave de autenticação). Assim:
  - Alice cria a mensagem m, concatena s com m e cria $s + m$, e calcula o hash H($s + m$). H($s + m$) é denominado código de autenticação da mensagem (MAC). (continua...)

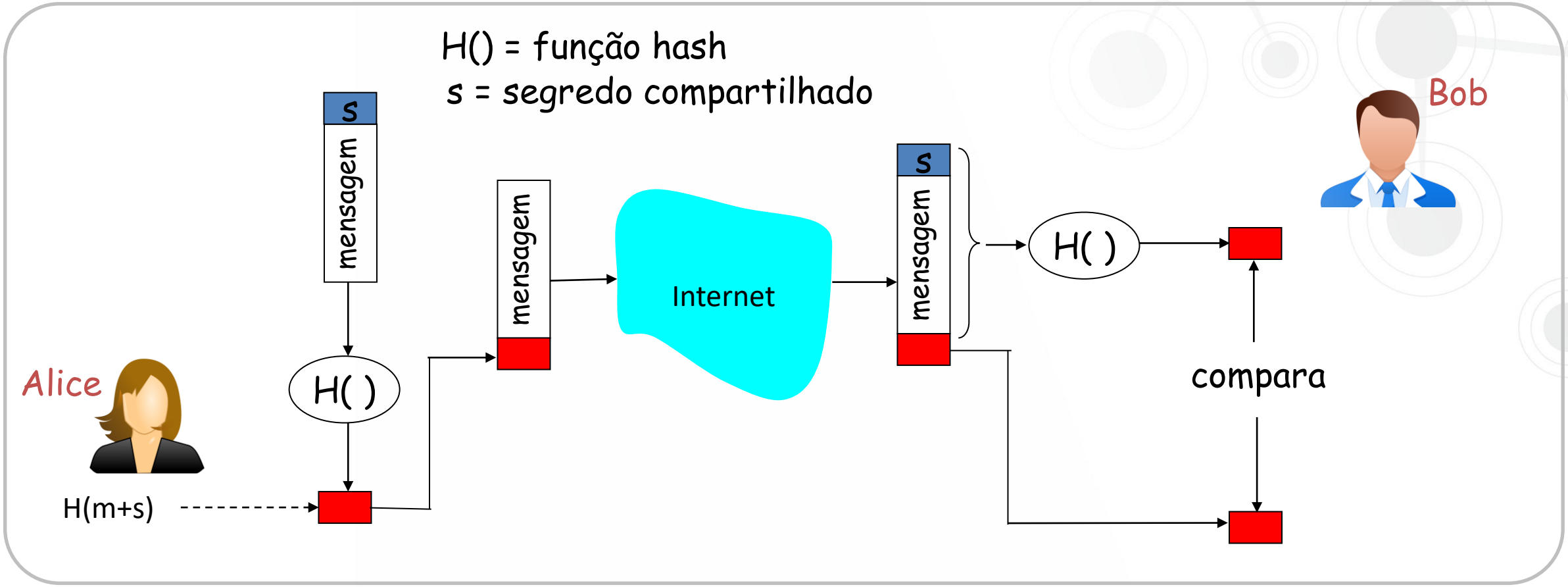
Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Message Authentication Code (MAC)

- Alice anexa o MAC à mensagem m (m, H($m + s$)).
- Bob recebe uma mensagem estendida (m, h) e conhecendo s, calcula o MAC H($m + s$). Se H($m + s$) = h, Bob conclui que está tudo certo.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Message Authentication Code (MAC)



Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Message Authentication Code (MAC)

- O MAC verifica integridade da mensagem
- sem criptografia!
- também chamado “hash chaveado”.
- Muito usado em algoritmo de roteamento de estado de enlace para autenticar a mensagem (onde não se preocupa com o sigilo da mesma).

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Message Authentication Code (MAC)

- MAC – Demonstração (aula03_mac.ipynb)

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Autenticação do ponto final

Autenticação do ponto final

- Deseja ter certeza do remetente da mensagem – *autenticação do ponto final*
- Supondo que Alice e Bob tenham um segredo compartilhado s, e Alice queira enviar uma mensagem a Bob, Bob precisa ter certeza que a mensagem foi enviada por Alice.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Autenticação do ponto final

- MAC oferecerá autenticação do ponto final
  - sabemos que Alice criou a mensagem
  - mas ela a enviou?

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Autenticação do ponto final

- Abordagem baseada em MAC:
  - Alice cria um MAC usando a mensagem e o segredo compartilhado.
  - Bob recebe a mensagem e usa o MAC anterior para verificar a fonte e a integridade da mensagem.
  - Assim, Bob sabe com certeza que Alice enviou a mensagem.
  - Mas será que ele sabe mesmo?

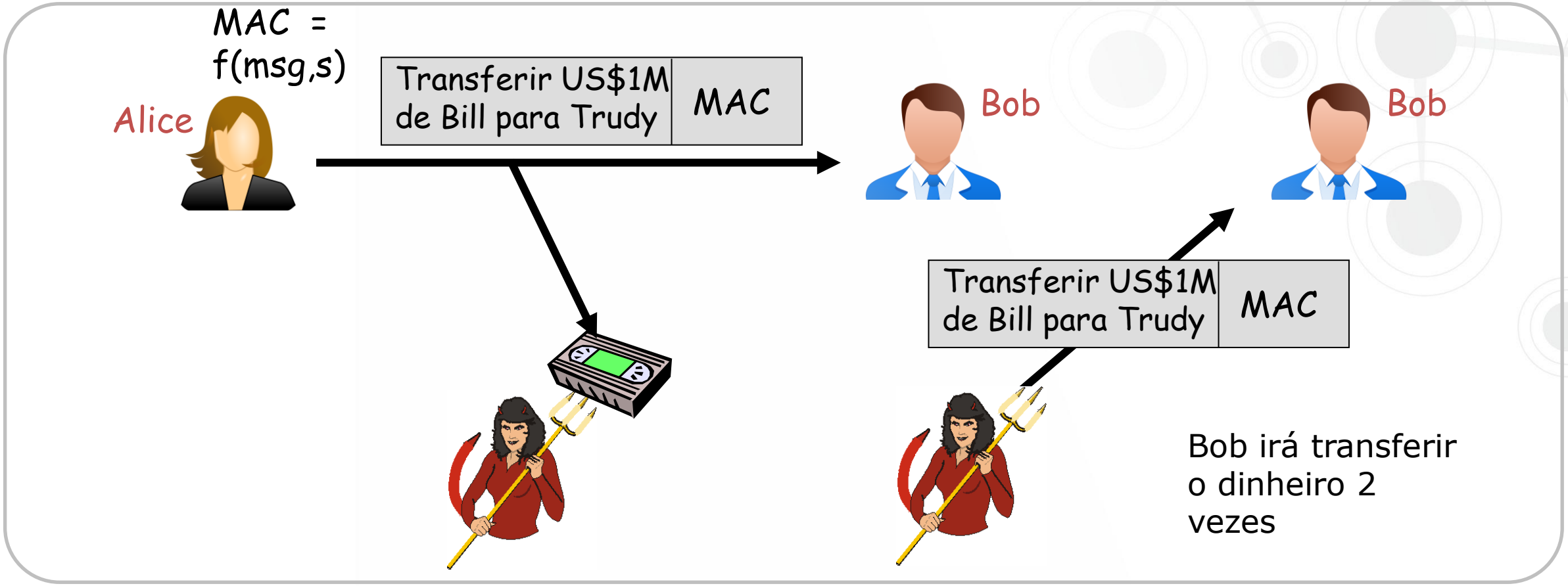
Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Ataque de reprodução

- Bob pode estar sendo enganado por um **ataque de reprodução**.
- O invasor poderia apenas gravar a mensagem de Alice quando ela envia uma mensagem para Bob.
- Mesmo sem o atacante saber o segredo s, pois ela simplesmente reproduz a mensagem.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Ataque de reprodução



Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Ataque de reprodução

- Como Bob pode saber se Alice realmente enviou duas mensagens?
  - **Nonce**: número que o protocolo usará somente uma vez em toda a vida.

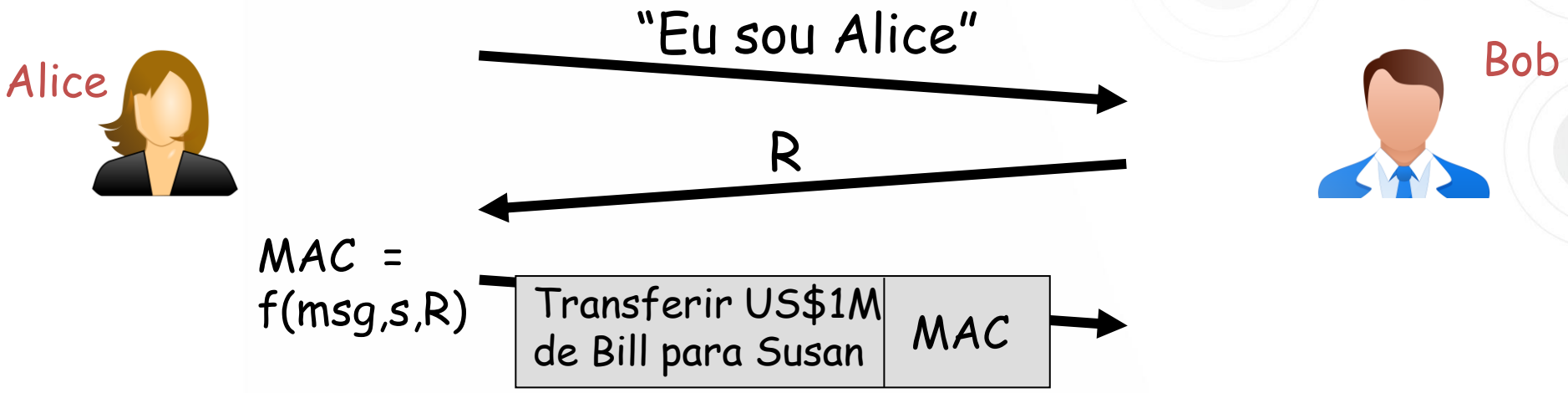
Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Ataque de reprodução

- Bob escolhe um nonce R e o envia a Alice (enviado em aberto). Alice cria o MAC utilizando sua mensagem original m, o segredo compartilhado s, e o nonce R (podendo concatenar os três).
- Alice anexa o MAC a mensagem, e envia a Bob

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Defendendo contra ataque de reprodução



Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Defendendo contra ataque de reprodução

- Bob calcula o MAC da mensagem. Se for igual ao MAC da mensagem estendida, Bob saberá que Alice criou a mensagem e que ela criou depois que ele enviou o R.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas Digitais

Assinaturas digitais

- Semelhante a ideia da assinatura no mundo real, devem ser verificável e não falsificável.
  - Provar que um documento assinado por uma indivíduo foi na verdade assinado por ele e que somente aquele indivíduo poderia ter assinado.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

- Remetente (Bob) assina documento digitalmente, estabelecendo que é o dono/criador do documento.
- Objetivo semelhante a um MAC, exceto que agora usamos criptografia de chave pública.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

- Verificável, não falsificável: destinatário (Alice) pode provar a alguém que Bob, e ninguém mais (incluindo Alice), deverá ter assinado o documento.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

- O que usar como assinaturas digitais?
  - Pode usar o MAC?
  - R.: quando Bob assina uma mensagem ele deve colocar algo único para ele. O MAC deveria ser conhecido por Alice também, para verificar a mensagem, portanto o MAC **não** poderia ser usado.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

- Lembre-se das chaves públicas: Bob tem uma chave pública e uma privada, que são **únicas** para Bob. Pode ser uma excelente candidata.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

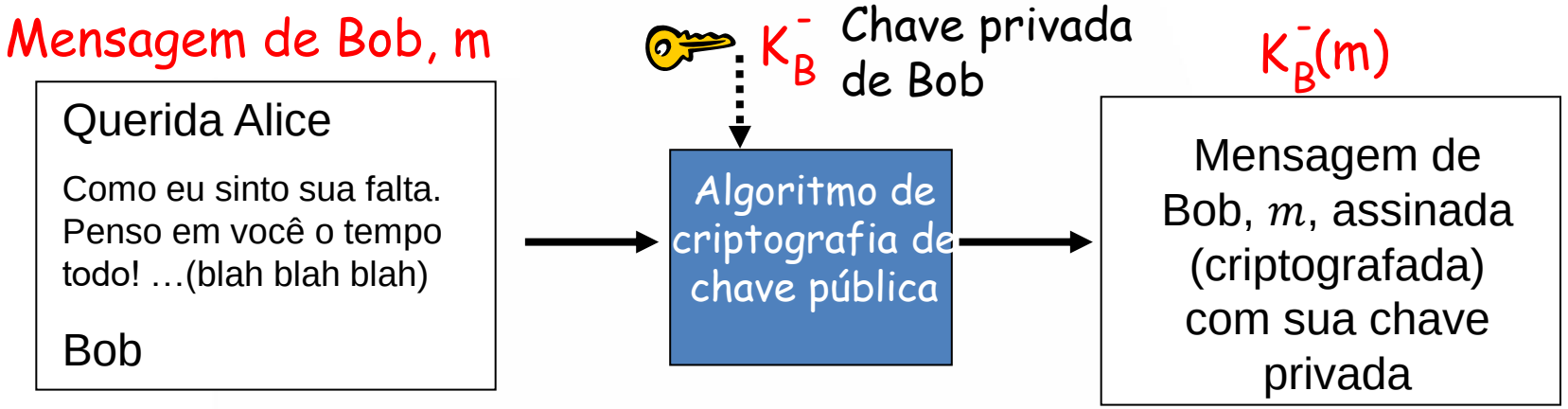
- Suponha que Bob queira assinar digitalmente um documento m (uma mensagem).
- Para assinar o m, Bob usa sua chave privada. Assim:

$$K_B^-(m)$$

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinatura digital simples para mensagem m

- Bob assina m criptografando com sua chave privada, K_B^- criando mensagem "assinada", $K_B^-(m)$



Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

$$K_B^-(m)$$

- Será que atende a exigência de ser verificável e não falsificável?

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

- Suponha que Alice tenha m e $K_B^-(m)$
- Ela deseja comprovar que Bob de fato assinou o documento e que era a única pessoa que poderia ter assinado.
- Alice pega a chave pública de Bob K_B^+ e aplica a assinatura digital $K_B^-(m)$ associada ao documento m.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

- Ou seja:

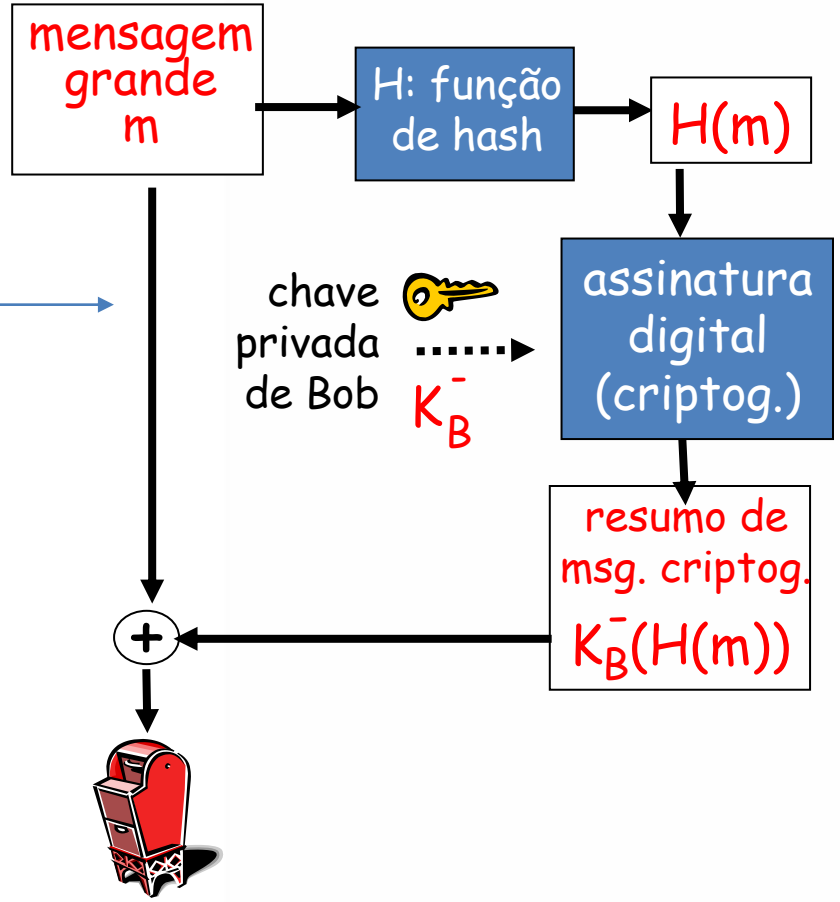
$$K_B^+(K_B^-(m))$$

- E assim ela produz m.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

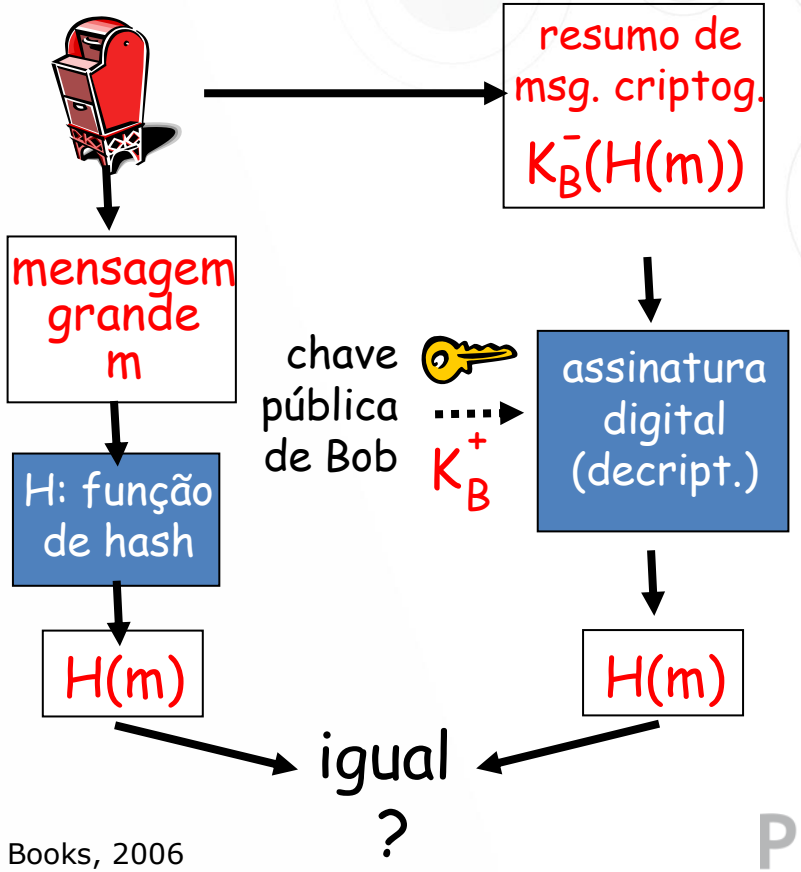
Assinatura digital = resumo de mensagem assinada

Bob envia mensagem assinada em forma digital:



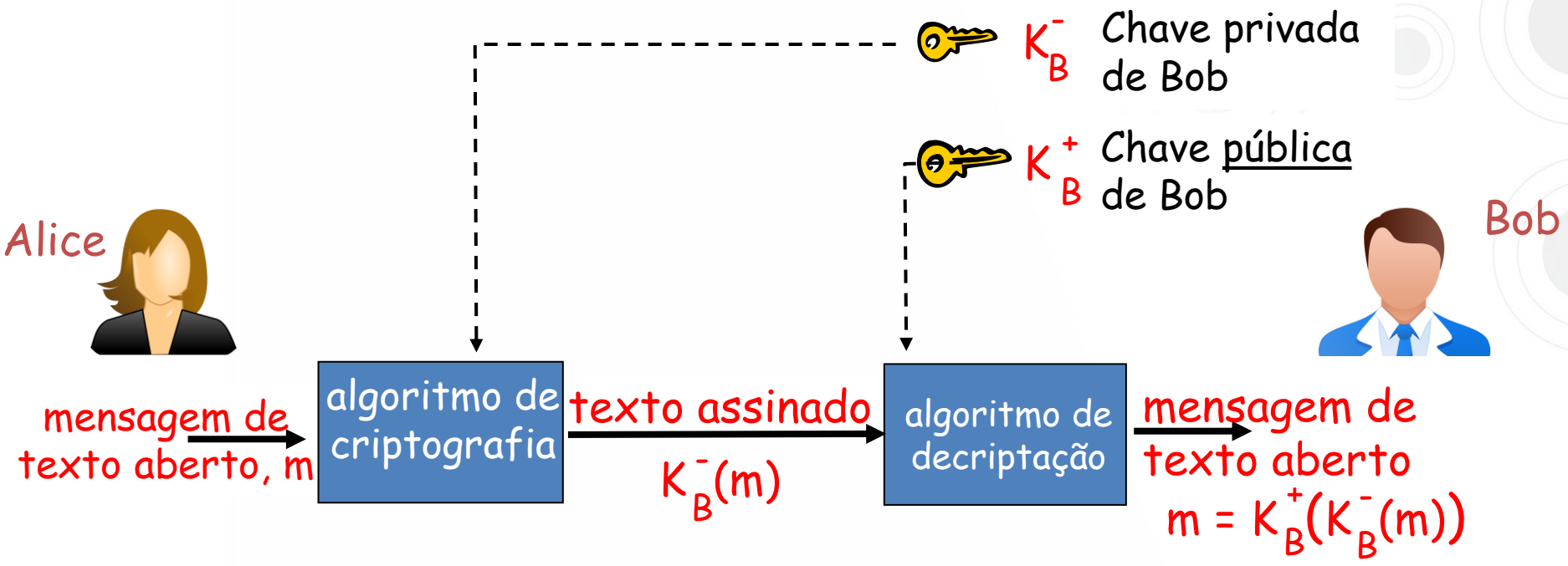
Observe que m é enviada aberta junto com a assinatura digital

Alice verifica assinatura e integridade da mensagem assinada em forma digital:



Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais



Mas como ter as garantias?

Assinaturas digitais

- Suponha que Alice receba mensagem m e a assinatura digital $K_B^-(m)$
- Alice verifica m assinada por Bob aplicando chave pública de Bob K_B^+ a $K_B^-(m)$, depois verifica $K_B^+\left(K_B^-(m)\right) = m$

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

- Garantia: se $K_B^+\left(K_B^-(m)\right) = m$, quem assinou m deve ter usado a chave privada de Bob.
- A única pessoa que poderia conhecer a chave é Bob (pois conhecer a chave publica não serve para descobrir a chave privada).

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

- Portanto a única pessoa que poderia conhecer $K_B^-(m)$ é Bob.
- Assim, Alice verifica se:
  - Bob assinou m.
  - Ninguém mais assinou m.
  - Bob assinou m e não m'.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

- Não repudiação:
  - Alice pode levar m e assinatura $K_B^-(m)$ ao tribunal e provar que Bob assinou m.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Assinaturas digitais

- Demonstração: aula03_sign.ipynb

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Certificação de chaves públicas

Certificação de chaves públicas

- Trote da pizza: Suponha que Trudy envie uma mensagem para a Alice dizendo que é Bob, fornece o endereço de Bob e pede a pizza.
  - Trudy cria pedido por e-mail:

    "*Prezada pizzaria, Por favor, me entregue quatro pizzas de calabresa. Obrigado, Bob*". (cont...)

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Certificação de chaves públicas

- Trudy assina pedido com sua chave privada
- Trudy envia pedido à pizzaria
- Trudy envia à pizzaria sua chave pública, mas diz que é a chave pública de Bob.
- pizzaria verifica assinatura; depois, entrega quatro pizzas para Bob.
- Bob nem sequer gosta de calabresa.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Certificação de chaves públicas

- Para que a criptografia de chaves públicas seja útil, você precisa ser capaz de verificar se você tem a chave pública verdadeira da entidade com o qual quer se comunicar.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Autoridades de certificação

- Esta tarefa é feita por um entidade certificadora (CA), cuja tarefa é validar identidades e emitir certificados.
  - Ela deve ser confiável
  - Cria um certificado que vincula a chave pública da entidade à identidade vinculada.

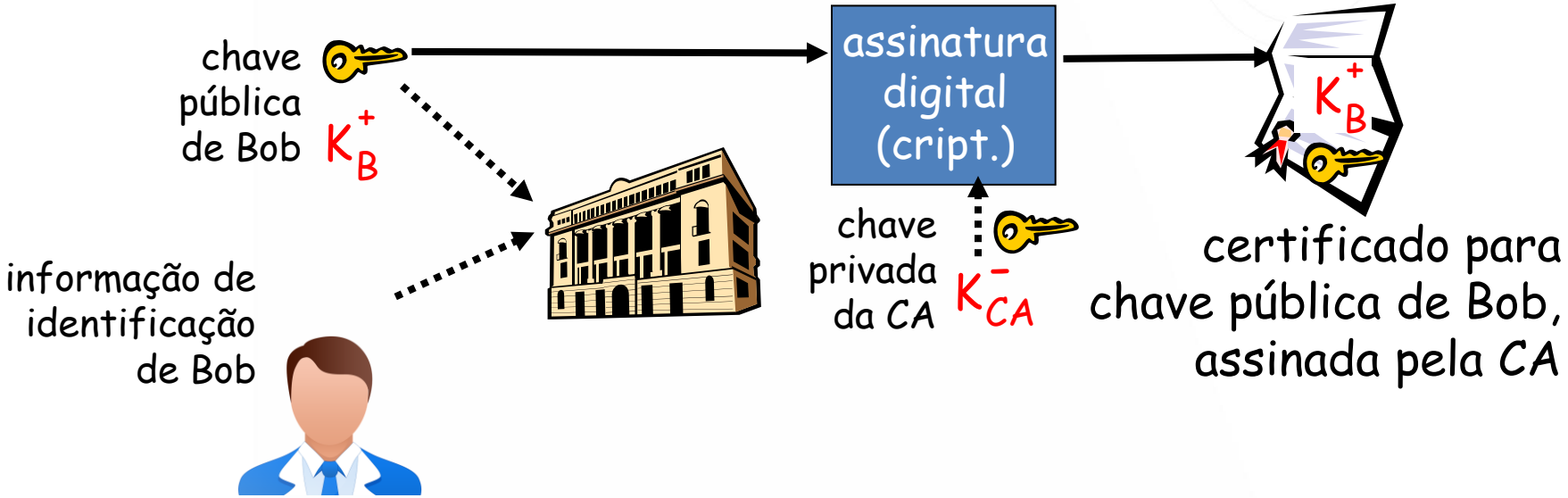
Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Certificação de chaves públicas

- Autoridade de Certificação (CA): vincula chave pública à entidade particular, E.
- E (pessoa, roteador) registra sua chave pública com CA.
  - Entidade E fornece "prova de identidade" à CA.
  - CA cria certificado vinculando E à sua chave pública.
  - Certificado contendo chave pública de E assinada digitalmente pela CA – CA diz "esta é a chave pública de E"

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

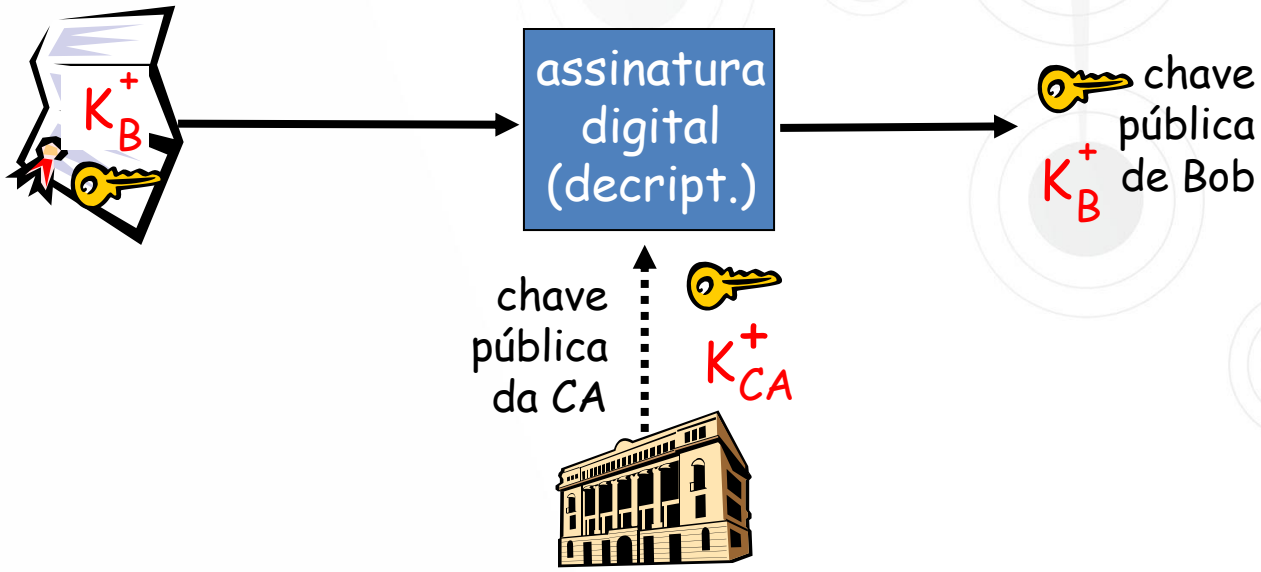
Autoridades de certificação



Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Autoridades de certificação

- Quando Alice quer a chave pública de Bob:
  - recebe certificado de Bob.
  - aplica chave pública da CA ao certificado de Bob, recebe chave pública de Bob



Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

SSL: Secure Sockets Layer

SSL: Secure Sockets Layer

- Protocolo de segurança bastante implantado
  - aceito por quase todos os navegadores e servidores Web
  - https (identifica que o SSL está sendo usado)
  - dezenas de bilhões de US$ gastos por ano sobre SSL

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

SSL: Secure Sockets Layer

- originalmente projetado pela Netscape em 1993. Oferece:
  - Confidencialidade
  - Integridade
  - Autenticação

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

SSL: Secure Sockets Layer

- objetivos originais:
  - teve em mente transações de comércio eletrônico na Web
  - criptografia (especialmente números de cartão de crédito)
  - autenticação de servidor Web
  - autenticação de cliente opcional. (cont...)

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

SSL: Secure Sockets Layer

  - mínimo de incômodo ao fazer negócios com novos comerciantes
- disponível a todas as aplicações TCP
  - Interface Secure Socket

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

SSL: Secure Sockets Layer

- Bob está navegando pela Web e decide comprar um perfume no site de Alice:
- Sem nenhuma medida de segurança, o que pode acontecer:
  - Sem sigilo (encriptação), um invasor intercepta o pedido de Bob e recebe informações sobre seu cartão; (cont...)

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

SSL: Secure Sockets Layer

- Sem integridade, o invasor poderia modificar o pedido de Bob;
- Sem autenticação, o site de compras poderia ser falso (se passando por site de compras)

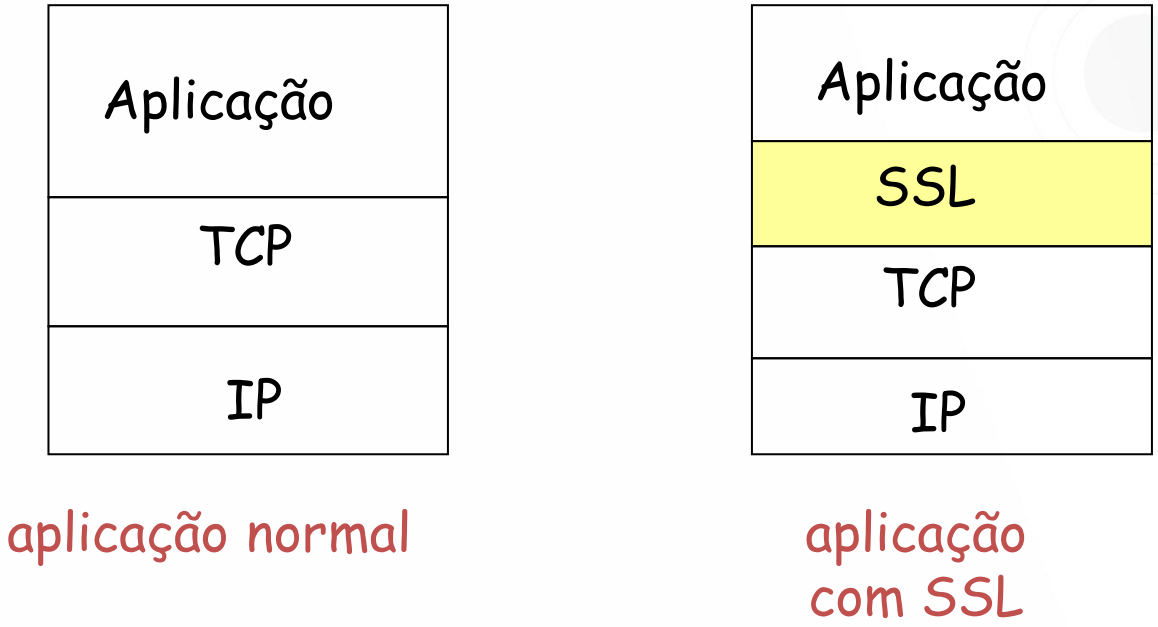
Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

SSL: Secure Sockets Layer

- É usado para oferecer segurança em transações que ocorrem através de HTTP. Entretanto, como o SSL protege o TCP, ele pode ser empregado por qualquer aplicação que execute o TCP.
- Apesar de ser da camada de aplicação, ele é um protocolo de transporte com segurança.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

SSL e TCP/IP



SSL oferece interface de programação de aplicação (API) às aplicações

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

SSL: um canal seguro simples

- apresentação: Alice e Bob usam seus certificados e chaves privadas para autenticar um ao outro e trocar segredo compartilhado
- derivação de chave: Alice e Bob usam segredo compartilhado para derivar conjunto de chaves

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

SSL: um canal seguro simples

- transferência de dados: dados a serem transferidos são desmembrados em uma série de registros
- encerramento de conexão: mensagens especiais para encerrar conexão com segurança

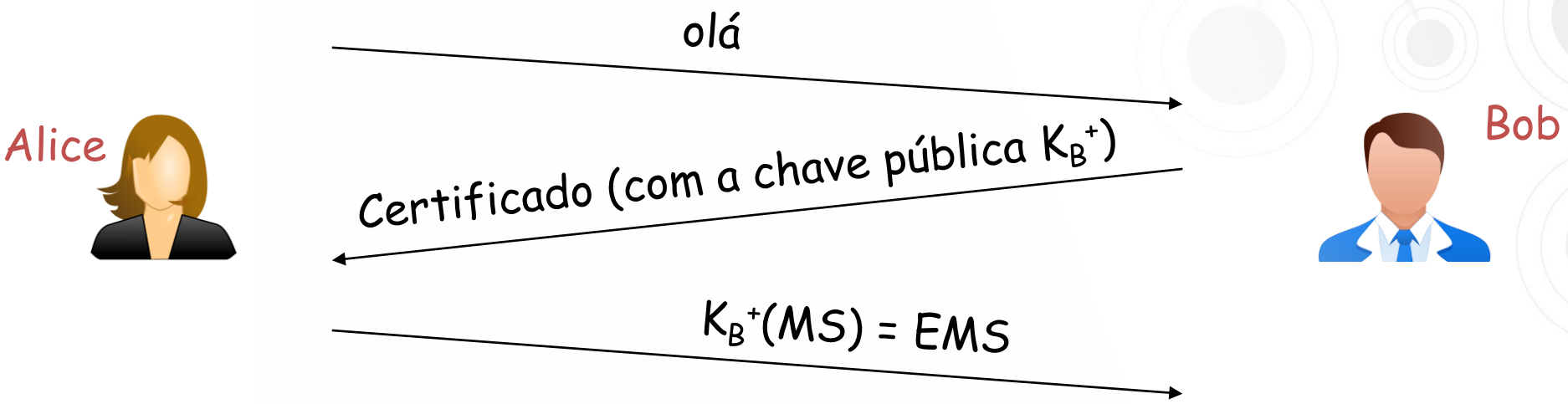
Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Uma apresentação simples

- Bob precisa (a) estabelecer uma conexão TCP com Alice, (b) verificar se Alice é realmente Alice, e (c) enviar para ela uma chave secreta mestre, que será utilizada pelos dois para criar todas as chaves simétricas que eles precisão na sessão.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Uma apresentação simples



- Alice sabe que o certificado é de Bob (pela CA)
- Alice cria um segredo mestre MS e codifica MS com a chave pública de Bob para criar o Segredo Mestre Criptografado (EMS)
- Bob decodifica EMS com sua chave privada para obter MS.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Derivação de chave

- Considerado ruim usar a mesma chave MS para mais de uma operação criptográfica
  - usar chaves diferentes para código de autenticação de mensagem (MAC) e criptografia (mais seguro)

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Derivação de chave

- Assim, Alice e Bob usam MS para criar quatro chaves.
  - E_B = chave de criptografia de sessão para dados enviados de bob para Alice
  - M_B = chave MAC de sessão para dados enviados de Bob para Alice
  - E_A = chave de criptografia de sessão para dados enviados de Alice para Bob
  - M_A = chave MAC de sessão para dados enviados de Alice para Bob

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Transferência de dados

- SSL quebra o fluxo em série de registros
  - cada registro transporta um mac
  - receptor pode atuar em cada registro quando ele chega
- Apesar disso, ainda não é a prova de falhas.

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Números de sequência

- Invasor pode capturar e reproduzir registro ou reordenar registros (como o homem do meio)
- solução: colocar número de sequência em MAC:
  - MAC = MAC(Mx, sequência||dados)

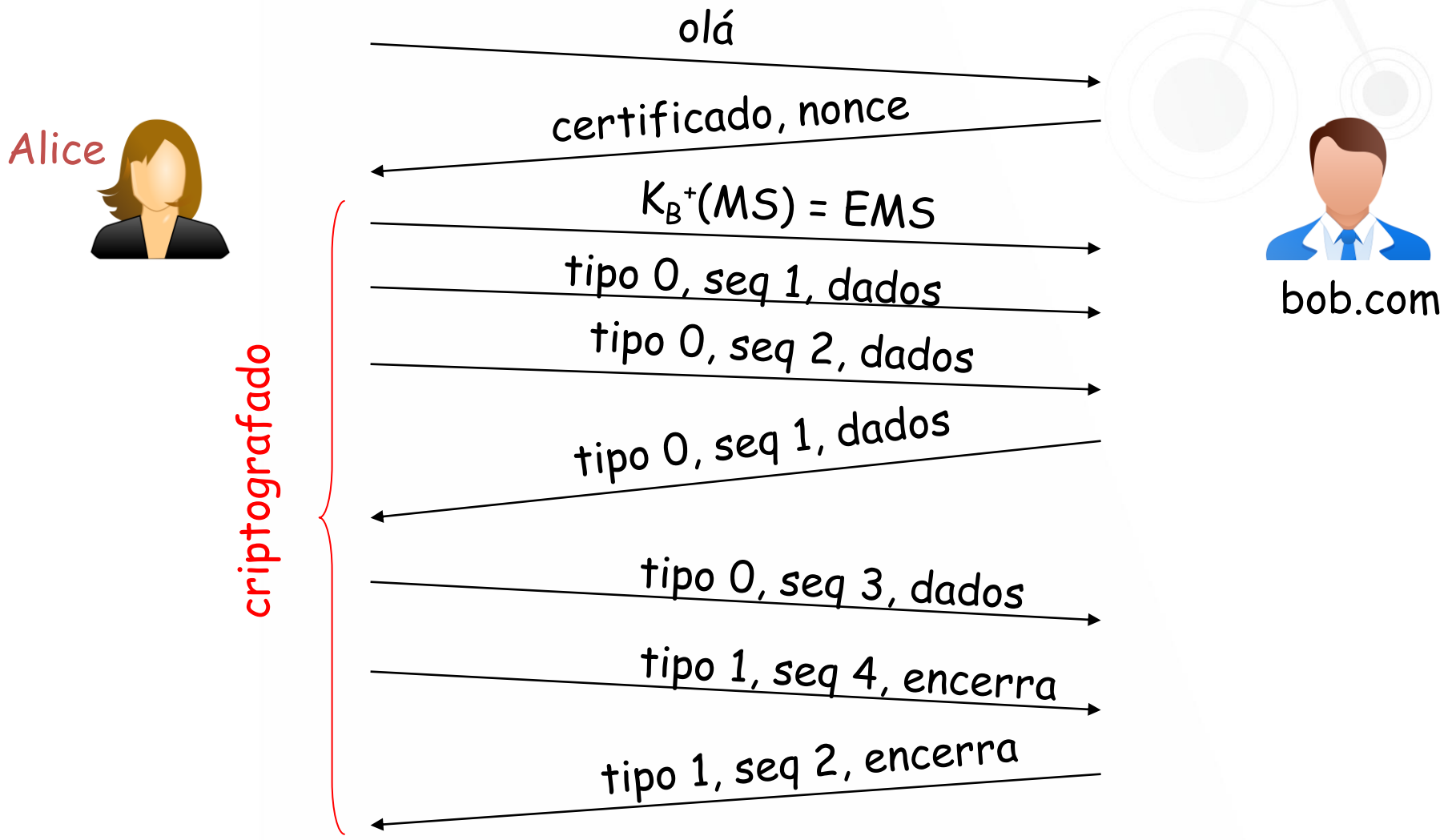
Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

Informação de controle

- ataque por truncamento:
  - invasor forja segmento de encerramento de conexão TCP
  - um ou ambos os lados pensam que existem menos dados do que realmente existem.
- solução: tipos de registro, com um tipo para encerramento
  - tipo 0 para dados; tipo 1 para encerramento
  - MAC = MAC(Mx, sequência||tipo||dados)

Referência: KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006

SSL - Resumo


Alice
bob.com
olá
certificado, nonce
$K_B^+(MS) = EMS$
tipo 0, seq 1, dados
tipo 0, seq 2, dados
tipo 0, seq 1, dados
tipo 0, seq 3, dados
tipo 1, seq 4, encerra
tipo 1, seq 2, encerra
criptografado

Referências

- KUROSE, James F. Redes de Computadores e a Internet. São Paulo: Makron Books, 2006.
- TANENBAUM, Andrew S. Redes de Computadores. 5ª Edição: Campus, 2003
- CHESWICK, William R.; BELLOVIN, Steven M.; RUBIN, Aviel D. Firewalls e Segurança na Internet. 2 ed. Porto Alegre: Bookman, 2005